



National Geospatial-Intelligence Agency

INSTRUCTION

NUMBER 5401.1

26 January 2020

MOC

SUBJECT: Privacy and Civil Liberties Program

References: See Enclosure 1.

1. PURPOSE. This Instruction:

a. Establishes policy, assigns responsibilities, delegates authorities, and provides procedures for complying with privacy and civil liberties responsibilities, including the establishment of a comprehensive framework to protect personally identifiable information (PII) entrusted to NGA, as well as ensuring that NGA effectively addresses privacy and civil liberties concerns in all aspects of its authorized missions and functions.

b. Rescinds: (1) NGA Manual (NGAM) 5500.1, "Privacy Act System of Records Notices (SORNs) and Privacy Impact Assessment (PIA) Process," 05 March 2013, administrative update 23 November 2015; (2) NGAM 5500.2, "Implementing Privacy Incident Response," 05 March 2013, administrative update 23 November 2015; (3) NGA Instruction (NGAI) 5500.7, "Handling of Personally Identifiable Information," 15 February 2013; and (4) NGA Instruction (NI) 1401.1, "NGA Instruction for Elimination of Unnecessary Personally Identifiable Information (PII) and Social Security Numbers (SSN)," 10 July 2010, administrative update 15 June 2011.

2. APPLICABILITY. This Instruction applies to all NGA civilian employees, military service members, other Government agency personnel assigned to NGA, and contractors, hereinafter referred to as NGA *personnel*.

3. DEFINITIONS. See Glossary.

4. POLICY. It is NGA policy that:

a. NGA collects, uses, maintains, or disseminates PII only when legally authorized, directly relevant, and necessary for purposes of discharging its missions and functions, and strives to eliminate any unnecessary collection, use, or dissemination of SSNs in accordance with (IAW) References (k) and (m), balancing the individuals' right to be protected against unwarranted invasion of privacy, and consistent with Federal law and policy.

UNCLASSIFIED

b. NGA ensures the security and confidentiality of all records containing PII and protects against any anticipated threats or hazards to their security or integrity that could result in substantial harm, embarrassment, inconvenience, or unfairness to any individual on whom information is maintained IAW References (j), (m), and (v).

c. NGA protects the civil liberties and legal rights of individuals in the development and use of information-sharing environments IAW References (i) and (m).

d. All NGA personnel affirmatively protect the privacy of all individuals when collecting, maintaining, using, or disseminating PII. Personnel with access to NGA systems or information have a responsibility to protect and secure PII held in any format and to report and properly respond to suspected or confirmed breach incidents.

e. NGA records and maintains an inventory of applicable electronic systems and hard-copy paper records that contain PII. To protect against data breaches, NGA takes a risk-based approach to protecting the confidentiality of PII and minimizing the collection and holding of PII to only what is necessary.

5. RESPONSIBILITIES. See Enclosure 2.

6. PROCEDURES. See Enclosure 3.

7. EFFECTIVE DATE. This Instruction is effective on the date of signature.



Robert D. Sharp
VADM, USN
Director

Enclosures

1. References
2. Responsibilities
3. Privacy and Civil Liberties Program
4. NGA Breach Response and Reporting Procedures

Glossary

UNCLASSIFIED**TABLE OF CONTENTS**

CHANGE LOG	4
ENCLOSURE 1: REFERENCES.....	5
ENCLOSURE 2: RESPONSIBILITIES	7
Director, NGA.....	7
Executive Director	7
Director, Mission Oversight and Compliance.....	7
Chief, Privacy and Civil Liberties Division	8
Chief Information Officer	10
Director, Human Development	11
General Counsel	11
Director, Security and Installations	11
Director, Office of Corporate Communication	12
Director, Office of Contract Services	12
Inspector General	13
Chief Financial Executive	13
Directorate Heads and Agency Element Leads	13
Program Manager/Information System Owners.....	13
Personnel.....	14
ENCLOSURE 3: PRIVACY AND CIVIL LIBERTIES PROGRAM	15
Fair Information Practice Principles.....	15
General Rules of Conduct for Handling PII.....	15
Privacy Threshold Analysis	15
Privacy Impact Assessment	16
System of Records Notices	17
Privacy Act Statement.....	18
Privacy Inspections Program.....	20
Social Security Number Reduction.....	21
Individual Access and Amending or Appealing Privacy Act Information	21
Privacy and Civil Liberties Role-based Training	22
Privacy and Civil Liberties Consultations.....	22
APPENDIX 1: Privacy Threshold Analysis (PTA) Process Flow	25
APPENDIX 2: DoDM 5240.01 Privacy and Civil Liberties Consultation Process	26
ENCLOSURE 4: NGA BREACH RESPONSE AND REPORTING PROCEDURES	27
APPENDIX 1: Breach Response Process Flow.....	30
GLOSSARY	31
FIGURES	
Figure 1. Example: Required Privacy Act Statement Information.....	18
Figure 2. Example: NGA Form Privacy Act Statement	19
Figure 3. Example: Website Privacy Act Statement	19
Figure 4. Example: Email Privacy Act Statement	19
Figure 5. Example: Third-Party Privacy Act Statement	20

UNCLASSIFIEDCHANGE LOG

Change	Change Date	Revised By	Pages Affected	Change Description

UNCLASSIFIEDENCLOSURE 1REFERENCES

- (a) 5 US Code § 522a, Privacy Act of 1974, as amended
- (b) Public Law 107-347, E-Government Act of 2002
- (c) 32 Code of Federal Regulations (C.F.R.), Part 310, Protection of Privacy and Access to and Amendment of Individual Records Under the Privacy Act of 1974
- (d) 48 C.F.R. Ch. 1, Federal Acquisition Regulation, 01 October 2019
- (e) 48 C.F.R. Ch. 2, Defense Acquisition Regulations System, Department of Defense, 01 October 2019
- (f) Office of Management and Budget (OMB) Memorandum M-17-05, Fiscal Year 2016–2017, “Guidance on Federal Information Security and Privacy Management Requirements,” 04 November 2016
- (g) OMB Memorandum M-17-12, “Preparing for and Responding to a Breach of Personally Identifiable Information,” 03 January 2017
- (h) Committee on National Security Systems, Instruction No. 1253, Appendix F, Attachment 6, “Privacy Overlay,” 23 April 2015
- (i) Intelligence Community Directive 107, “Civil Liberties, Privacy, and Transparency,” 28 February 2018
- (j) DoD Directive (DoDD) 5200.27, “Acquisition of Information Concerning Persons and Organizations Not Affiliated with the Department of Defense,” 7 January 1980
- (k) DoD 5400.11-R, “Department of Defense Privacy Program,” 14 May 2007
- (l) DoD Instruction (DODI) 1000.30, “Reduction of Social Security Number (SSN) Use Within DoD,” 01 August 2012
- (m) DoDI 5400.11, “DoD Privacy and Civil Liberties Programs,” 29 January 2019
- (n) DoDI 5400.16, “DoD Privacy Impact Assessment (PIA) Guidance,” 14 July 2015, Change 1, 11 August 2017
- (o) DoDI 7750.07, “DoD Forms Management Program,” 10 October 2014
- (p) DoD Manual 5240.01, “Procedures Governing the Conduct of DoD Intelligence Activities,” 08 August 2016
- (q) Deputy Secretary of Defense Memorandum, “Reporting of Breaches of Personally Identifying Information in Accordance with the Department of Defense Breach Response Plan,” 30 November 2018
- (r) NGA Directive (NGAD) 1025, “Mandatory Training,” 06 May 2015, Administrative update 4, 09 May 2018
- (s) NGAD 8000, “Information Management and the Chief Information Officer,” 12 June 2013, Administrative Update 2, 28 October 2015
- (t) NGAD 8010, “Information Systems Risk Management Framework (RMF),” 27 August 2015, Administrative Update 1, 16 November 2015
- (u) NGAI 5750.1, “Freedom of Information Act/Privacy Act Requests/Mandatory Declassification Review Program,” 06 July 2018
- (v) NGAI 8040.2, Vol. 1, “Records and Information Lifecycle Management: Records Management Program,” 30 March 2016
- (w) NGAI 8900.4, “Intelligence Oversight Compliance and Awareness Program,” 18 July 2019

UNCLASSIFIED

- (x) NGAI 8900.5, "Domestic Imagery," 02 January 2020
- (y) NGAM 1455.1, "Disciplinary and Adverse Actions," 19 February 2015, Administrative Update 11, 12 April 2019
- (z) NGAM 8010.1, "Information Systems (IS) Risk Management Framework (RMF) Guide," 24 July 2015, Administrative Update 1, 06 December 2018

UNCLASSIFIEDENCLOSURE 2RESPONSIBILITIES

1. Director, NGA (D/NGA).

a. Ensures NGA procedures protect individual privacy rights and civil liberties IAW References (a), (c), (j), (k), and (m).

b. Delegates responsibility to manage and supervise the functions of the NGA Privacy and Civil Liberties Program to the Director, Mission Oversight and Compliance (D/MOC).

c. Designates the Executive Director (EXDIR), except for records of the Office of Inspector General (OIG), as the Appellate Authority (AA) for NGA Privacy Act (PA) requests to amend records IAW References (c) and (k).

d. Designates the D/MOC as the Senior Component Official for Privacy (SCOP) to support the DoD Senior Agency Official for Privacy (SAOP).

e. Designates the Inspector General (IG) as the AA for NGA PA requests to amend records of the OIG IAW References (c) and (k).

2. EXDIR.

a. Serves, except for records of the OIG, as the AA for denials of requests to amend PA records.

b. Reviews, except for records of the OIG, appeals of denials of requests to amend PA records and provides a decision in writing IAW References (c) and (k).

3. D/MOC.

a. Manages and supervises the functions of the NGA Privacy and Civil Liberties Program.

b. Serves as the SCOP to oversee and provide strategic direction for the NGA Privacy and Civil Liberties Program IAW References (n) and (p).

c. Collaborates with the DoD SAOP on NGA privacy and civil liberties issues and concerns. (Reference (n))

d. Coordinates with the Chief Information Officer (CIO) and Chief Information Security Officer (CISO) on granting authorization to operate decisions for information systems that create, collect, use, process, store, maintain, disseminate, disclose, or dispose of PII.

UNCLASSIFIED

e. Ensures adequate procedures are in place for the management and remediation of privacy and civil liberties complaints and alleged violations. (Reference (m))

f. Informs D/NGA of any actual or suspected loss of control of PII, including unauthorized disclosure, unauthorized acquisition, or unauthorized access, concerning NGA personnel.

g. Implements the DoD Breach Response Plan and establishes an NGA Breach Response Plan for the loss of PII IAW References (m) and (q).

h. Ensures NGA personnel who have primary responsibility for implementing the NGA Privacy and Civil Liberties Program receive appropriate training. (Reference (m))

i. Reviews and approves documents and reports for submission to the Defense Privacy, Civil Liberties, and Transparency Division (DPCLTD).

j. Coordinates PIAs as the SCOP IAW References (m) and (n), before PIA submission to the Director, Chief Information Office and Information Technology (IT) Services Directorate (CIO-T), for approval.

k. Delegates responsibility for administering NGA's Privacy and Civil Liberties Program to the Chief, Privacy and Civil Liberties Division (C/MOCP).

l. Oversees development, implementation, and maintenance of a Privacy Inspection Program (PIP). The PIP includes planned, limited notice, and no-notice privacy inspections for verification that Directorates and Agency Elements are reporting Privacy Act violations. In addition, the PIP ensures NGA personnel are trained on and comply with privacy and civil liberties responsibilities IAW Reference (k) and this Instruction.

4. C/MOCP.

a. Supports the SCOP as the NGA Chief Privacy and Civil Liberties Officer.

b. Manages and supervises MOCP staff to ensure NGA personnel protect individual privacy rights and civil liberties through compliance with appropriate Federal law and policy.

c. Receives, responds to, and investigates (in consultation with OIG as necessary) reports of actual or suspected compromise, or other loss of control, of PII. After determining whether a breach incident occurred, conducts and documents risk assessments of potential harm to individuals as a result of the compromised PII.

d. Identifies appropriate administrative, physical, and technical safeguards and procedures, ensuring compliance with all applicable Federal laws, regulations, policies, and procedures to protect PII. (Reference (k))

UNCLASSIFIED

e. Collaborates with NGA information management, information collection, information security, forms and publications management, records management, CIO-T, and General Counsel (GC) on privacy and civil liberties matters established in References (a), (k), and (u).

f. Coordinates with the Office of Corporate Communications (OCC) to ensure that NGA PIAs are available to the public, IAW References (m) and (n), on the NGA public-facing website.

g. Establishes mechanisms for NGA personnel to report privacy and civil liberties complaints or alleged violations IAW Reference (k).

h. Assists the SCOP in implementing the NGA Breach Response Plan and establishing NGA breach response procedures.

i. Plans, executes, and participates in an annual NGA Breach Response Team (BRT) tabletop exercise.

j. Evaluates the severity of breach incidents and advises the SCOP on the appropriate course of action for reporting, mitigation, and remediation.

k. Collaborates with the Security and Installations (SI) Directorate to ensure that the Office of Insider Threat (SII) and Office of Security (SIS) include privacy and civil liberties functions and principles in its training IAW Reference (m).

l. Manages the Privacy Threshold Analysis (PTA) and PIA processes to ensure that appropriate administrative, technical, and physical safeguards are implemented, ensuring the security and confidentiality of PII IAW Reference (n).

(1) Develops and implements procedures for the use of NGA PTAs to assess PII in NGA information systems and collection of categories of records, reviews and approves the PTA, and arbitrates PII interpretations and recommendations.

(2) Manages the NGA PIA approval process, and reviews and coordinates with appropriate signatories on DD Form 2930, "Privacy Impact Assessment," for information systems IAW References (m) and (n).

(3) Maintains records of the completed PTA and provides copies to individual Information System (IS) owners and CIO-T Risk Management for incorporation in the system Assessment and Authorization (A&A) package, IAW References (t) and (v).

m. Reviews and provides recommendations to the SCOP for modification or approval of a SORN and exemption rules for submission to DPCLTD. Develops and implements NGA SORN procedures and implements SORN best practices.

UNCLASSIFIED

(1) Collaborates with Program Manager (PM)/IS owners to manage SORN development, modification, and retirement; conduct reviews; and make approval recommendations IAW Reference (k).

(2) Maintains records of completed SORNs and continuously monitors each NGA SORN to ensure currency and accuracy.

(3) Coordinates with DPCLTD if a Directorate or Agency Element contemplates a computer matching agreement (CMA) and processes any requests for a CMA IAW Reference (k).

n. Provides oversight of the collection, use, and dissemination of SSNs through the PTA and PIA process and prepares SSN use and justification memorandums for review and approval by the SCOP, for submission to DPCLTD IAW References (k) and (n).

o. Submits reports required by References (k), (m), (n), and (q) to the Chief, DPCLTD.

p. Coordinates with SI to conduct a review of PII holdings upon request or at least annually.

q. Ensures MOCP staff receives appropriate privacy and civil liberties training IAW Reference (m).

r. Establishes an NGA program to provide employee awareness of privacy and civil liberties as well as supervisors' and senior leaders' understanding of responsibilities to protect privacy and civil liberties IAW Reference (m).

s. Unless exempted under Reference (a), processes requests to correct or amend NGA PA records, in conjunction with Directorate Heads/Agency Element Leads, if it is determined that such records are not accurate, relevant, timely, or complete.

t. Processes and fulfills requests from individuals to amend personal records or appeal a denial to amend personal records pertaining to those individuals IAW References (a), (k), and (u).

5. CIO.

a. Serves as the NGA PIA approval official IAW Reference (n).

b. Coordinates with D/MOC prior to granting authorization to operate decisions for information systems that create, collect, use, process, store, maintain, disseminate, disclose, or dispose of PII.

c. Ensures Directorate Heads and Agency Element Leads apply the appropriate privacy overlays and protections to IT systems IAW References (h), (n), (s), (t), and (z).

UNCLASSIFIED

d. Notifies the SCOP within 24 hours of a cyber- or systems-related breach involving the loss or compromise of PII.

e. Designates a CIO-T representative to participate on the NGA BRT and provides necessary resources or assistance to facilitate mitigation or remediation.

f. Assesses the impact of technology on privacy and adopts privacy-enhancing technology in collaboration with MOCP IAW Reference (n).

6. Director, Human Development (D/HD).

a. Ensures protection of NGA PII contained in HD systems and holdings IAW Reference (n).

b. Designates an HD representative to participate on the NGA BRT and provides necessary resources or assistance to facilitate mitigation or remediation.

c. Grants MOCP access to the New Employee Orientation Seminar (NEOS) to provide mandatory privacy and civil liberties introductory training session to all new NGA personnel IAW Reference (k).

d. Ensures the Health Clinic reviews PII holdings upon MOCP request or at least annually.

7. GC.

a. Provides legal guidance, opinion, and determination on applicable Federal laws, regulations, policies, and procedures.

b. Designates an Office of General Counsel (OGC) representative to participate on the NGA BRT and provides necessary resources or assistance to facilitate mitigation or remediation.

c. Provides legal advice and assistance to the BRT as necessary.

d. Provides legal advice and guidance on requests to amend PA records, appeals, and associated litigation and collaborates on privacy consultations supporting NGA missions excluded from References (p) and (w).

e. Coordinates and provides legal concurrence on PIAs and SORNs.

8. Director, Security and Installations (D/SI).

a. Ensures that the SI Office of Security Information Management Division (SISMD) coordinates with MOCP upon receipt of a request from individuals to amend personal

UNCLASSIFIED

records or appeal a denial to amend personal records pertaining to those individuals for processing and fulfilling the amendment or appeal IAW References (a), (k), and (u).

b. Collaborates with MOCP to ensure the NGA Insider Threat Program and Personnel Security includes privacy and civil liberties functions and principles in insider threat training IAW References (k), (n), and (r).

c. Assists MOCP with investigations into breach incidents as required.

d. Designates an SI representative to participate on the NGA BRT and provides necessary resources or assistance to facilitate mitigation or remediation.

e. Ensures that the NGA Forms Manager periodically evaluates NGA forms that require PII for accurate PA statements IAW Enclosure 3.

9. Director, Office of Corporate Communication (D/OCC).

a. Designates an OCC representative to participate in the BRT and provides necessary resources or assistance to facilitate mitigation or remediation.

b. Coordinates with the SCOP and others for external notification to affected third parties and the issuance of press releases for major breach incidents.

c. Coordinates with C/MOCP to ensure NGA PIAs are available to the public, IAW References (m) and (n), on the NGA public-facing website.

d. Signs all external correspondence associated with requests to amend PA records, in coordination with D/MOC and D/SI.

e. Serves as point of contact for media-related inquiries about breach incidents.

f. Maintains a central repository of NGA PIAs on the NGA public-facing website IAW Reference (n).

10. Director, Office of Contract Services (D/OCS).

a. Ensures that solicitations and contracts include appropriate clauses incorporating privacy requirements, caveats, training, and protective provisions IAW References (d) and (e).

b. Reports to MOCP any breach incidents or breach–major incidents reported to OCS by contractors or their parent companies.

UNCLASSIFIED

11. IG.

- a. Serves as the AA for NGA PA requests to amend records of the OIG IAW References (c) and (u).
- b. Reviews appeals of requests to amend PA records of the OIG and provides decisions in writing IAW References (c) and (u).
- c. Consults with the BRT on a case-by-case basis as necessary.

12. Chief Financial Executive designates a representative to participate in the BRT to provide necessary resources or assistance with the funding implications of BRT decisions to facilitate mitigation or remediation.

13. Directorate Heads and Agency Element Leads.

- a. Designate a representative to participate on the BRT upon request of the SCOP and provide necessary resources or assistance for mitigation or remediation.
- b. Develop and implement corrective actions in collaboration with MOCP when breach incidents or breach-major incidents occur.
- c. Ensure all NGA forms that contain PII include PA statements IAW Reference (o).
- d. Consider Fair Information Practice Principles (FIPPs) when evaluating IS, processes, programs, and activities that affect individual privacy rights and civil liberties IAW Reference (n).
- e. Unless exempted under Reference (a), correct or amend NGA PA records, in conjunction with C/MOCP, if it is determined that such records are not accurate, relevant, timely, or complete.

14. PM/IS Owners.

- a. Coordinate with MOCP for completion of all privacy compliance documentation before adding or modifying NGA systems of records. A PM/IS owner creates a system of records when information is retrievable about an individual using a unique identifier and requires a privacy review IAW References (k) and (m).
- b. Maintain records of completed privacy documentation IAW Reference (v).
- c. Collaborate with MOCP to develop a new or modified SORN submission and assist in biannual SORN reviews. PM/IS owners notify MOCP of any changes to the system of records that impacts a SORN published in the Federal Register.

UNCLASSIFIED

d. Notify MOCP when a suspected or confirmed breach incident or breach–major incident occurs.

e. Apply FIPPs when evaluating IS, processes, programs, and activities that affect individual privacy rights and civil liberties IAW Reference (m).

15. Personnel.

a. All NGA personnel with access to NGA systems or information share responsibility to protect and secure PII held in any format and to properly handle suspected or confirmed breach incidents or breach–major incidents IAW Reference (g). Personnel who fail to safeguard PII as required by Federal law or policy, including NGA directives and instructions, are subject to disciplinary action commensurate with the nature of the offense, responsibilities and duties of the individual, and the magnitude of the incident, including resultant harm, consistent with established practice and applicable policies IAW Reference (y).

b. Report privacy and civil liberties complaints or alleged violations of the PA to MOCP or OIG.

c. Recognize and report suspected or confirmed breach incidents or breach–major incidents to an immediate supervisor, PM, MOCP, or OIG as soon as possible and without unreasonable delay.

d. Complete the mandatory annual computer-based training course NGA SEC3301, Privacy Awareness Training, IAW Reference (r).

UNCLASSIFIEDENCLOSURE 3PRIVACY AND CIVIL LIBERTIES PROGRAM

1. FIPPs. All NGA Directorates and Agency Elements consider FIPPs when evaluating information systems, processes, programs, and activities that affect individual privacy, consistent with the DoD mission and Privacy and Civil Liberties program requirements IAW Reference (m). PM/IS owners consult with MOCP when they cannot implement particular principles and identify other considerations to address identified privacy and civil liberties risks.

2. General Rules of Conduct for Handling PII.

a. Collection, use, and dissemination of personal information by NGA personnel are legally authorized, relevant, and reasonably deemed necessary to accomplish a DoD function IAW Reference (m).

b. When it is not possible to collect PII directly from the individual and PII is collected from third parties, PII is verified with the subject of the record to the greatest extent practicable before NGA uses the PII.

c. NGA's Freedom of Information Act and Transparency Office manages disclosure of records pertaining to an individual from a system of records.

d. NGA maintains no records on how individuals exercise their First Amendment rights except as provided for under the Privacy Act of 1974.

e. NGA makes reasonable efforts to ensure records are accurate, timely, and relevant before disseminating them to other federal or non-federal agencies IAW Reference (k).

3. PTA.

a. NGA uses PTA as a tool to manage privacy risks. The privacy compliance process begins with conducting a PTA, which serves as the official determination whether a system of records has privacy implications requiring a PIA, a SORN, or further compliance documentation. NGA will conduct PTA on all new systems and systems undergoing re-accreditation. See PTA flowchart in Appendix 1 to Enclosure 3 of this Instruction.

b. The PM/IS owner collaborates with CISO to begin the Intelligence Community Directive 503 Risk Management Framework (RMF) authorization process and coordinates with MOCP to initiate a PTA.

c. MOCP provides the PM/IS owner with a PTA Form and guides the PM/IS owner through to completion of the form.

UNCLASSIFIED

(1) The PM/IS owner assesses a new or modified IT system to determine the Potential Impact Value using of the MOCP PTA Form, IAW Reference (h), for Federal Information Processing Standards (FIPS) Publication 199 security categorization determination. The PM/IS owner determines the six factors outlined in National Intelligence Support Team (NIST) 800-122 for Confidentiality Impact Levels IAW Reference (h). The PM/IS owner provides the completed NGA PTA Form to MOCP for a privacy overlay review and assessment IAW Reference (h).

(2) If MOCP determines the system requires a PIA, the PM/IS owner completes the PIA process IAW Section 4 of this Enclosure.

(3) If MOCP determines the system does not require a PIA or any additional privacy documentation, it provides a copy of the PTA to the PM/IS owner indicating no further action is required.

(4) If MOCP determines the system does not require a PIA, but must have a SORN, the PM/IS owner completes a SORN IAW Section 5 of this Enclosure.

d. MOCP provides the PM/IS owner and the Designated Approval Official Representative (DAOR) with the final PTA, and maintains copies of all privacy documentation IAW records management requirements in Reference (v).

4. PIA. When a PTA determines that a PIA is required, the PM/IS owner completes the PIA process IAW Reference (n).

a. MOCP provides the PM/IS owner with DD Form 2930 "Privacy Impact Assessment," initiating the PIA approval process IAW Reference (n).

b. MOCP determines whether the system requires a SORN.

(1) If an existing SORN is applicable, the PM/IS owner enters the SORN system identifier on the DD Form 2930.

(2) If a new SORN is required, the PM/IS owner completes a SORN IAW Section 5 of this Enclosure.

c. The PM/IS owner completes and returns the PIA form to MOCP for review and coordination to obtain the required signatures IAW Reference (n). The PIA requires:

(1) Section 1: PII Description Summary. The PM/IS owner provides the PII Description Summary.

(2) Section 2: PII Risk Review. CISO conducts a PII Risk Review IAW FIPS 199 Privacy Impact Review in collaboration with MOCP and

(a) Applies privacy overlay IAW Reference (h).

UNCLASSIFIED

(b) Mitigates all identified privacy risks to the fullest extent possible during system development or procurement.

(3) Section 3: Related Compliance Information. CIO, the PM/IS owner, the Information Management Control Officer, MOCP, and GC ensure that the PIA complies with Reference (n) and properly applies privacy overlays IAW References (b) and (h).

(4) Section 4: Review and Approval Signature. A final review by MOCP ensures that the coordinated PIA is complete IAW PA requirements and References (k) and (n).

d. MOCP provides the PIA to the CIO for final review and approval. Upon approval, MOCP provides approved DD Form 2930 to the DoD CIO IAW Reference (n).

e. MOCP provides final signed DD Form 2930 to the PM/IS owner and DAOR for inclusion in the A&A package.

f. MOCP, in collaboration with CIO and OCC, ensures NGA makes Section 1 of its PIAs available on the NGA public-facing website IAW Reference (n).

g. MOCP reviews and updates existing PIAs every three years, or when a significant change in the system occurs, IAW Reference (n).

5. SORN. When a PTA or PIA determines a SORN is required, the PM/IS owner completes the SORN process IAW Reference (m).

a. If an IT system collects PII from individuals, and information within the system is retrievable by personal identifier (e.g., name, date of birth, employee Identification number, SSN, or any other identifier assigned to an individual), NGA publishes a SORN in the Federal Register before the system becomes operational.

b. Creating a New SORN. MOCP assists the PM/IS owner in preparing SORN documentation IAW DPCLTD guidelines, and coordinates with OGC for legal review. MOCP submits completed SORN documentation to DPCLTD for review and subsequent submission to the Federal Register.

c. Modifying an Existing SORN. PM/IS owners provide MOCP details of any change in the SORN. MOCP documents modifications in the supplementary information section of the SORN, and forwards it to DPCLTD for review and submission to the Federal Register.

d. Rescinding an Existing SORN. When a system of records is no longer being maintained, is no longer accessible by individuals' name or other identifiers, or has been consolidated with another system of records, the PM/IS owner:

UNCLASSIFIED

(1) Consults the Directorate or Agency Element records manager to determine the appropriate method of destroying or transferring records to the appropriate location IAW Reference (u) and the approved records schedule.

(2) Forwards notice of SORN termination to MOCP for review. MOCP provides DPCLTD a termination notice for review and submission to the Federal Register.

6. Privacy Act Statement (PAS).

a. NGA uses PASs when collecting PII in any medium, IAW References (a) and (n). The PAS indicates to individuals that their information is being collected, the legal authority and purpose of the collection, and how the organization uses the information. See Figure 1, Example: Required Privacy Act Statement Information. PASs also indicate whether providing the information is mandatory or voluntary and the consequences of failing to provide the information. Individuals will be informed of:

- (1) The authority for collection.
- (2) The specific purpose or purposes for which the information is intended to be used.
- (3) How the PII may be used.
- (4) Whether disclosure of such information is mandatory or voluntary.
- (5) The consequences to the individual for not providing that information.

Authority: The federal statute or executive order that authorizes collection of the requested information.

Purpose: The principal purpose(s) for which the information is to be used.

Routine Uses: The routine uses that will be made of the information.

Disclosure: Whether providing the information is “voluntary” or “mandatory” and the effects on the individual if he or she chooses not to provide the requested information. It is only appropriate to cite “mandatory” when a federal law or executive order of the President specifically imposes a requirement to furnish the information and provides a penalty for failure to do so. If furnishing information is a condition for granting a benefit or privilege voluntarily sought by the individual, it is voluntary for the individual to give the information.

Figure 1. Example: Required Privacy Act Statement Information

UNCLASSIFIED

b. NGA identifies all records in any medium containing PII and includes a PAS. Personnel coordinate with OGC for concurrence to ensure PASs are legally accurate on records including NGA forms, websites, and emails.

(1) NGA forms. Directorate Heads and Agency Element Leads ensure a PAS is included on all component forms that may collect or contain PII. See Figure 2, Example: NGA Form Privacy Act Statement.

Information contained in this form and/or any corresponding attachments/artifacts may contain personally identifiable information and are for official use only.

Figure 2. Example: NGA Form Privacy Act Statement

(2) Website administrators for their respective organizations ensure websites containing PII provide a PAS. See Figure 3, Example: Website Privacy Act Statement.

Information contained in this site and/or any corresponding attachments/artifacts may contain personally identifiable information and are for official use only.

Figure 3. Example: Website Privacy Act Statement

(3) NGA personnel ensure all emails containing PII contain an email PAS. See Figure 4, Example: Email Privacy Act Statement.

PERSONAL DATA—PRIVACY ACT OF 1974: Information contained in this document and/or any corresponding attachments/artifacts may contain personally identifiable information and are for official use only. If you have received this document in error, please advise the sender immediately and destroy this document together with all attachments. All unintended recipients are hereby advised that any use, distribution, copying, or any other action regarding this communication (email, etc.) is strictly prohibited. Unauthorized dissemination or use of personally identifiable information is a violation of Federal law. Individuals in violation may be subject to fines, disciplinary actions, or both.

Figure 4. Example: Email Privacy Act Statement

(4) NGA posts a PAS on the third-party websites or applications collecting PII for NGA, and includes the following information IAW Reference (c). See Figure 5, Example: Third-Party Privacy Act Statement.

(a) Explain that the website or application is not a government website or application, that it is controlled or operated by a third party, and that NGA's Privacy and Civil Liberties policy does not apply to the third party;

UNCLASSIFIED

(b) Indicate whether and how NGA maintains, uses, or disseminates PII that becomes available through the use of the third-party websites or applications;

(c) Explain that by using the website or application to communicate with NGA, individuals may be providing nongovernment third parties access to PII;

(d) Direct individuals to NGA's official website; and

(e) Direct individuals to NGA's Privacy and Civil Liberties policy.

Third-Party Privacy Act Statement: The application being used to collect your information is not a government website or application. It is controlled or operated by a third party under the name of **[ENTER NAME HERE]**, and the Privacy and Civil Liberties policy of the National Geospatial-Intelligence Agency (NGA) does not apply to this third party.

The information collected is used to **[XXX (example: *to evaluate individuals for specific employment opportunities*)]**. The requested information is used to **[XXX (example: *determine your skills and experience, as well as your security eligibility, for employment with NGA*)]**.

By using the **[ENTER NAME HERE]** website or application to communicate with NGA, you may be providing nongovernment third parties access to Personally Identifiable Information (PII).

For additional information on NGA and NGA's Privacy and Civil Liberties policy, you can visit our official website at <https://www.nga.mil/> and read our Privacy and Civil Liberties policy at <https://www.nga.mil/About/Pages/Privacy.aspx>.

Figure 5. Example: Third-Party Privacy Act Statement

7. PIP. The MOC Program Management Office PIP evaluates compliance with Federal law and policy protecting privacy rights and civil liberties by routinely conducting inspections of Directorates and Agency Elements, operations, and programs. The inspections determine:

a. Whether unreported PA violations exist.

b. Whether personnel within inspected Directorates and Agency Elements are aware of their responsibility to report PA violations and procedures for submitting reports.

UNCLASSIFIED

c. Whether personnel within inspected Directorates and Agency Elements have completed NGA required annual PA training.

d. Whether the inspected Directorates and Agency Elements are in compliance with privacy and civil liberties governance.

8. SSN Reduction. NGA will reduce the use of SSNs in any format because use of SSNs has become increasingly sensitive.

a. MOCP provides oversight of the collection, use, and dissemination of SSNs through the PTA and PIA process IAW the approval guidelines in References (l) and (m).

(1) MOCP reviews requests to collect, use, or maintain SSNs and validates the requirements to collect, use, or maintain the SSN.

(2) For validated SSN requirements, PM/IS owners, in coordination with MOCP, draft SSN justification memorandums for SCOP review and signature.

(3) MOCP submits SCOP-signed SSN justification memorandums to DPCLTD for approval.

b. MOCP provides the DPCLTD-approved justification memorandums to PM/IS owners for inclusion with the appropriate A&A package.

c. MOCP continually monitors SSN justification memorandums, conducts comprehensive reviews at least triennially, and submits new SSN justification memorandums as necessary IAW Ref (l).

9. Individual Access and Amending or Appealing PA Information. Individuals may review their personal information maintained by NGA and may request an amendment to their personal information. If the Directorate or Agency Element denies a request to amend personal information in an NGA record, individuals can appeal the denial to the AA for NGA PA requests, IAW Reference (u), through SISMD.

a. NGA encourages personnel to review their personal information maintained by NGA. Individuals may request access to their personal information for review through SISMD procedures set forth in Enclosure 4 of Reference (u).

b. Amendment of PA Records. Individuals may request an amendment to any record in an NGA system of records pertaining to the individual IAW Reference (k). Individuals submit a request to amend an NGA PA record to SISMD.

(1) SISMD coordinates the PA amendment request with MOCP for processing and fulfilling the request.

UNCLASSIFIED

(2) The Directorate or Agency Element Lead responsible for maintaining the record evaluates the request and approves the change or denies the PA request.

c. In the event that a request to amend an individual's personal information in an NGA system of records is denied, the individual may appeal the denial.

(1) The individual submits an appeal request regarding the denial decision, IAW References (c) and (u), through SISMD to MOCP, in consultation with OGC, to the AA.

(2) SISMD notifies the requester of the AA appeal decision after coordination with MOCP and the Directorate or Agency Element responsible for maintaining the individual's record.

10. Privacy and Civil Liberties Training. MOCP conducts privacy and civil liberties training IAW Reference (k). The training includes:

a. NEOS Training. Provides initial introduction to and familiarization with privacy and civil liberties protections mandated by Federal law or policy.

b. Mandatory Annual Computer-Based Training (SEC3301 Privacy Awareness Training).

c. Privacy and Civil Liberties Role-Based Training.

(1) Tailored Privacy and Civil Liberties Training. Personnel assigned responsibilities to assess, manage, or use NGA information systems that contain PII are provided role-based privacy training at least annually, in addition to the mandatory NGA PA Computer-Based Training.

(2) Managerial Training. MOCP provides NGA managers with mission-specific training regarding operational programs and activities with privacy and civil liberties implications.

d. Insider Threat Training Coordination. MOCP conducts an annual review of NGA Insider Threat training to ensure that it includes privacy and civil liberties considerations IAW Reference (m).

11. Privacy and Civil Liberties Consultations.

a. DoD Manual 5240.01 requires DoD personnel to consult with privacy and civil liberties officials when conducting foreign intelligence (FI) and counterintelligence (CI) activities in several circumstances related to the collection, retention, and dissemination of US Persons Information (USPI). Requirements to consult with privacy and civil liberties include:

(1) Interpretations of, exceptions to, or amendments to DoDM 5240.01 (Reference (p)).

UNCLASSIFIED

(2) Collection activity constituting a Special Circumstances Collection IAW Reference (p).

(3) Requesting extended retention of unevaluated USPI.

(4) Consideration of disseminations of USPI not conforming to DoDM 5240.01 procedures (Reference (p)).

b. Personnel supporting NGA missions or activity not constituting FI or CI and excluded from the provisions of DoDM 5240.01 IAW Reference (p) who require the collection of USPI or PII also consult with MOCP when necessary for:

(1) Conducting excluded missions or functions according to References (p) and (x).

(2) Considering non-FI or -CI activities involving the collection of domestic imagery from airborne, handheld, and open sources IAW References (p) and (w).

c. NGA personnel initiate the consultation process (see Appendix 2 of Enclosure 3 of this Instruction) by submitting a request form available on the MOC, MOCP, or MOC Intelligence Oversight Division (MOCI) website with details of the requested consultation, including details of the USPI or PII being considered for collection, including:

(1) Reason for the consultation.

(2) Whether the activity constitutes an FI, CI, law enforcement, or excluded mission.

(3) Summary of the mission or activity leading to the consultation request. The summary includes:

(a) Determination of how the USPI/PII is collected (voluntarily provided, intentionally collected, or incidentally collected).

(b) Determination whether USPI/PII is retained, disseminated, or otherwise used by NGA.

d. MOC Program Management Office reviews requests for privacy and civil liberties consultations for clarification of the circumstances and requirements for a consultation and coordinates the consultations through MOCP, MOCI, and OGC (see Appendix (2)) as necessary.

e. MOCI evaluates privacy and civil liberties consultation requests for activities that involve FI and CI requiring a privacy or civil liberties consultation and forwards the

UNCLASSIFIED

request to MOCP for comments, advice, and/or guidance on the privacy or civil liberties implications of the planned activity, including limitations that apply to the planned collection of USPI or PII IAW References (m), (p), and (w), and this Instruction.

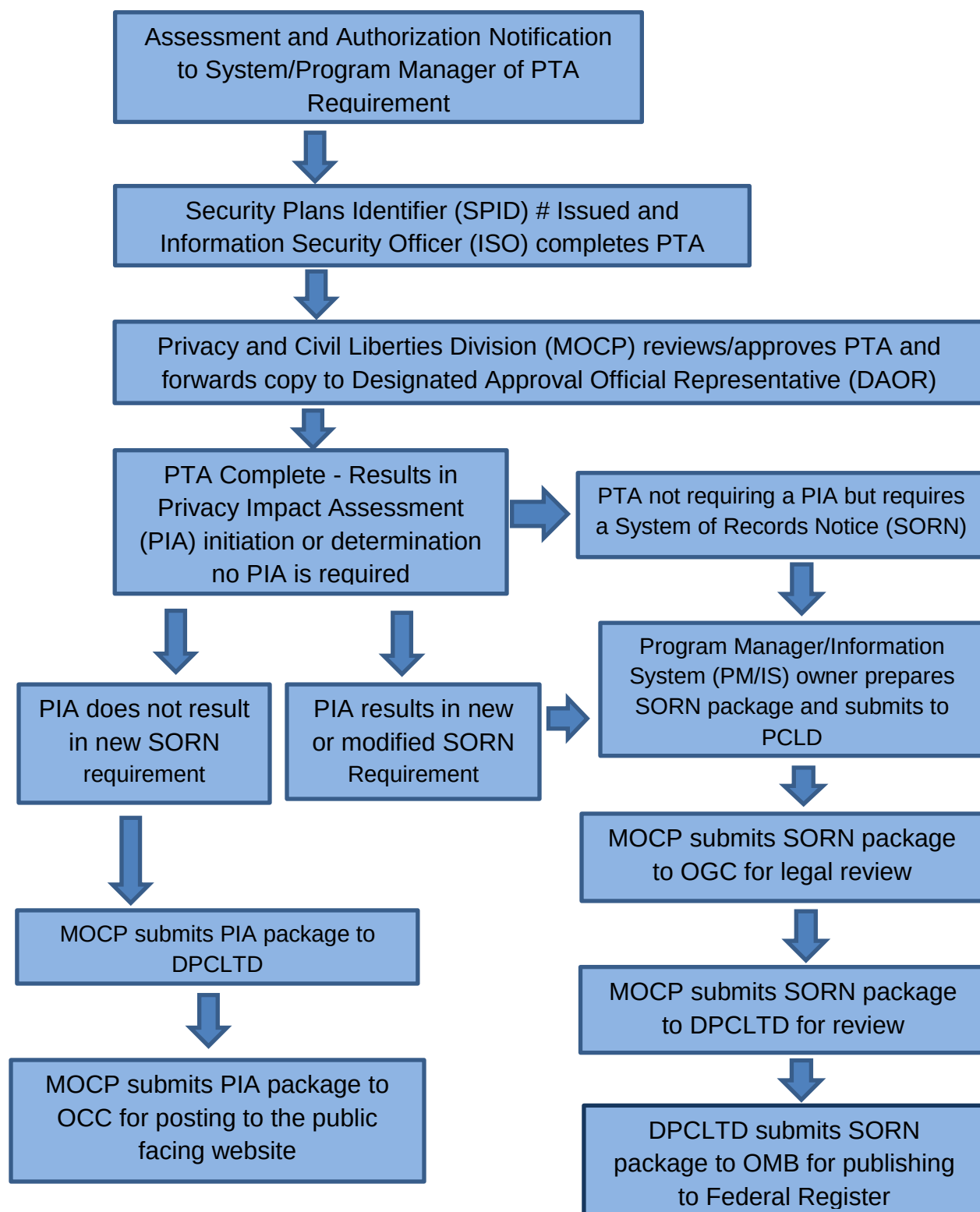
f. MOCP evaluates the privacy or civil liberties implications of planned activity involving non-FI/CI and provides recommendations on the handling of USPI or PII, including limitations that apply to USPI or PII IAW References (m), (p), (w), and (x).

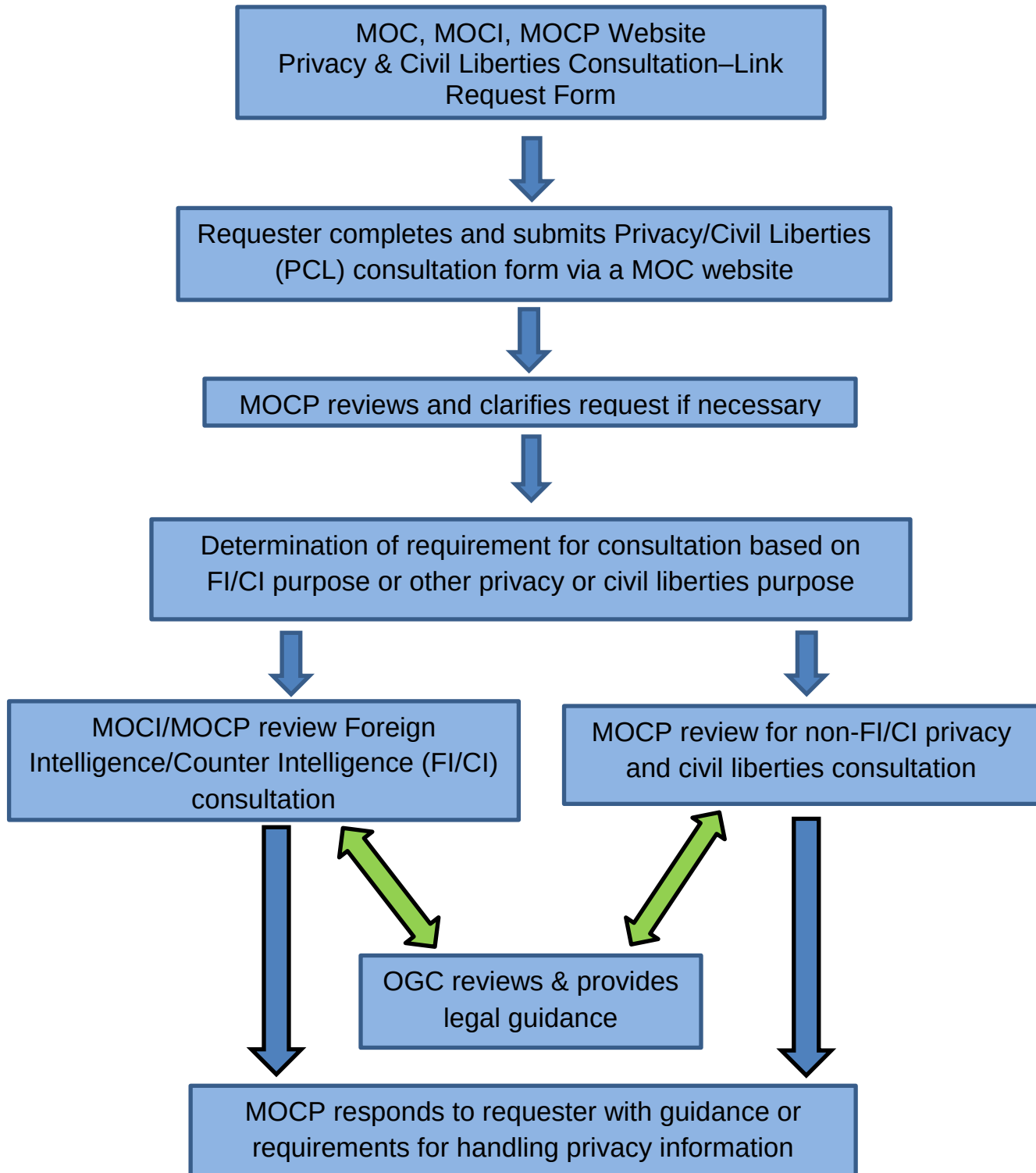
g. OGC provides a legal review of the planned collection, retention, and dissemination of USPI or PII IAW References (m), (p), (w), and (x).

h. Chief, MOCP or MOCI, provides a formal recommendation for the requesters' planned activity.

UNCLASSIFIED

APPENDIX 1 TO ENCLOSURE 3

Privacy Threshold Analysis (PTA) Process Flow

UNCLASSIFIEDAPPENDIX 2 TO ENCLOSURE 3DODM 5240.01 PRIVACY AND CIVIL LIBERTIES CONSULTATION
PROCESS**UNCLASSIFIED**

UNCLASSIFIEDENCLOSURE 4NGA BREACH RESPONSE AND REPORTING PROCEDURES

1. NGA personnel discovering a suspected or actual loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or unauthorized access of PII, whether paper records or electronic media, notify MOCP or OIG within one hour of discovery by the most expeditious means. (Contact NGA Operations Center after normal business hours.) MOCP notifies the SCOP within 24 hours and consults with OGC to determine whether a breach incident or breach–major incident occurred.

a. NGA personnel report suspected or actual breach incidents or breach–major incidents. The individual discovering the incident, in coordination with their supervisor, or program manager, notifies MOCP or OIG and provides basic information about the incident (e.g., who, what, when where, why, and how), including whether the incident involves PII.

b. An evaluation of the incident by MOCP and the SCOP, in consultation with OGC and any other Directorate or Agency Element as applicable, determines if the event is an incident, breach incident, or a breach–major incident.

c. The C/MOCP reports and coordinates NGA computer-based breach incidents with the United States Computer Emergency Readiness Team (US CERT) within one hour if appropriate.

d. MOCP manages breach incidents not constituting a breach–major incident, including notification to DPCLTD, investigation, and assistance with mitigation or remediation.

e. SCOP manages breach incidents constituting a breach–major incident using the NGA Breach Response Plan, supported by the BRT.

2. In the event a determination is made that a breach incident occurred, MOCP gathers additional information and assesses the severity and scope of the breach.

a. IS owners contain any loss of control or spillage of PII and mitigate potential harm to affected parties.

b. The C/MOCP consults with SI Computer Investigation and Awareness (SISC) for breach incidents involving IT systems where formal investigation procedures are appropriate.

c. The SCOP reports and coordinates NGA computer-based breach incidents with US CERT within one hour if appropriate.

UNCLASSIFIED

d. MOCP prepares and submits the initial report via Form DD-2959 "Breach of Personally Identifiable Information Report" to DPCLTD, with periodic updates as necessary until it closes the breach incident.

e. The impacted Directorate or Agency Element, in collaboration with MOCP, notifies personnel of the breach incident in a timely manner IAW Reference (k).

f. MOCP provides guidance or assistance in the development of specific corrective actions and conducts post-incident reviews, develops lessons learned, conducts training and education, and provides internal communications in order to minimize potential for future incidents.

g. Once mitigation and remediation efforts for the breach incident are completed, MOCP updates the Form DD-2959 for SCOP approval and recommends incident closure. MOCP prepares a closure Form DD-2959 for submission to DPCLTD.

3. Breach—Major Incident. A breach incident constitutes a breach—major incident when it involves PII that, if exfiltrated, modified, deleted, or otherwise compromised, is likely to result in demonstrable harm to the national security interests, foreign relations, or economy of the United States, or to the public confidence, civil liberties, or public health and safety of the American people.

a. The SCOP determines the likely risk of harm and level of impact of the breach—major incident in order to verify applicable reporting requirements, and whether and how to provide notification to individuals affected. MOCP prepares an initial assessment, along with all additional information developed regarding the breach—major incident for the SCOP's review. The SCOP, supported by MOCP, implements the NGA Breach Response Plan to investigate the breach—major incident, mitigate the damage, and communicate as necessary with NGA personnel.

b. The SCOP manages an NGA breach—major incident and activates the NGA BRT.

c. The BRT includes senior NGA officials with decision-making authority responsible for the response to and remediation of the breach—major incident (see Appendix 1 to Enclosure 4 of this Instruction). The BRT membership includes designees from the component experiencing the breach—major incident, the SCOP, C/MOCP, CIO (including the Cyber Security Operations Cell (CSOC), FM, SI (including SIS and SISC), OCC, OGC, HD, and any other Directorate or Agency Element as determined by the SCOP.

d. BRT members assist with additional analysis, response planning, and the assessment of containment activities IAW the NGA Breach Response Plan and established standard operating procedures. SISC acts as lead investigator for breach incidents involving NGA IT systems and investigates the loss, unauthorized disclosure, or misuse of NGA information and systems.

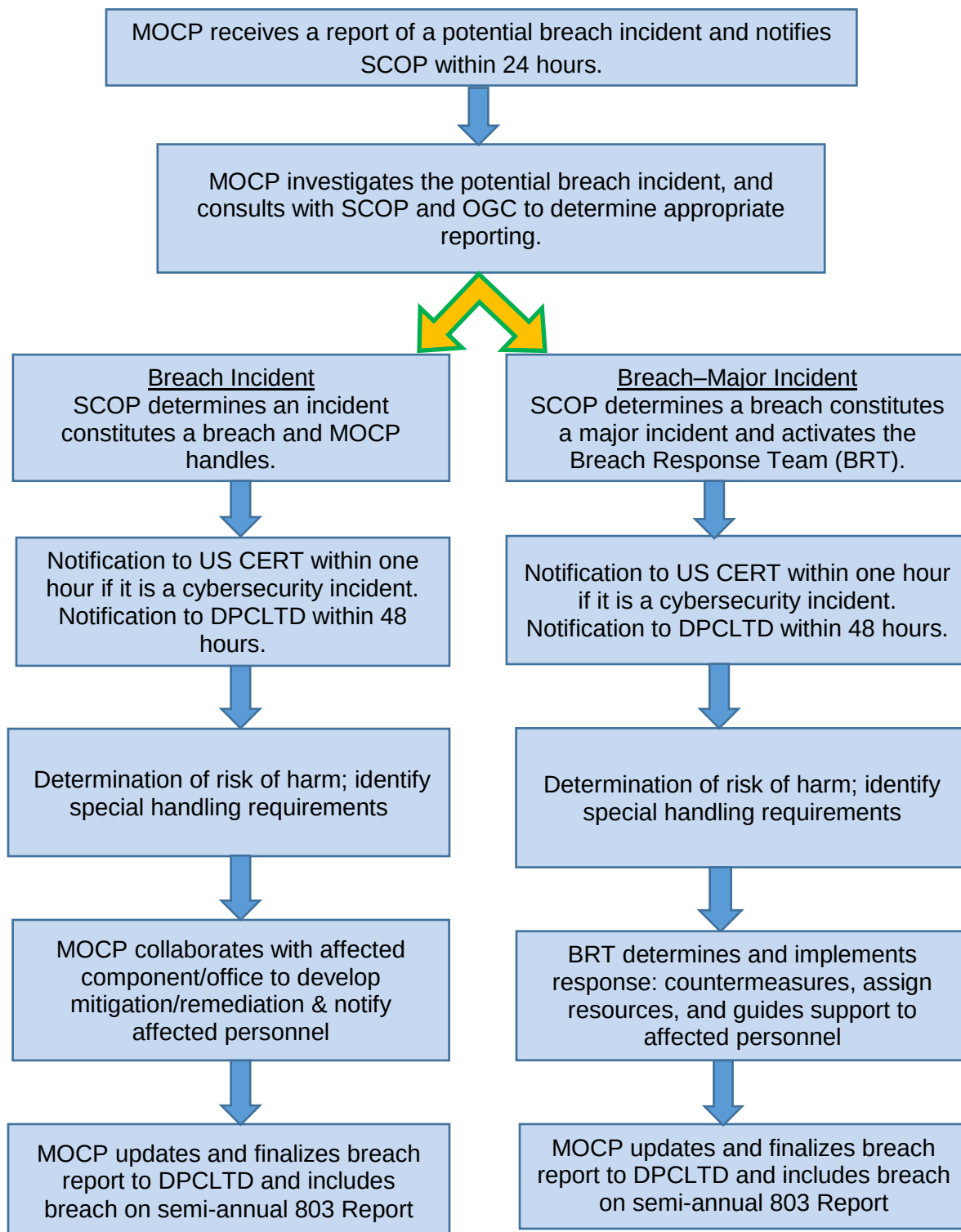
UNCLASSIFIED

e. Once mitigation and remediation efforts for the breach–major incident are completed, the BRT and MOCP update the After Action Report via Form DD-2959 for SCOP approval and recommend incident closure. MOCP prepares a closure Form DD-2959 for submission to DPCLTD.

f. The SCOP coordinates with the DoD SAOP and DPCLTD to provide a Supplemental Report of the Major Incident Breach, in collaboration with OCC, to appropriate DoD oversight Committees in Congress within 30 days after the initial report of the major incident breach.

UNCLASSIFIED

APPENDIX 1 TO ENCLOSURE 4
BREACH RESPONSE PROCESS FLOW



UNCLASSIFIEDGLOSSARYDEFINITIONS

Breach Incident	The loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (1) a person other than an authorized user accesses or potentially accesses personally identifiable information; or (2) an authorized user accesses or potentially accesses personally identifiable information for an other than authorized purpose. (Definition created by NGA for NGA purposes only; derived from Reference (g))
Breach—Major Incident	A breach constitutes a “major incident” when (1) it involves PII that, if exfiltrated, modified, deleted, or otherwise compromised, is likely to result in demonstrable harm to the national security interests, foreign relations, or economy of the United States, or to the public confidence, civil liberties, or public health and safety of the American people; or (2) it involves an unauthorized modification of, unauthorized deletion of, unauthorized exfiltration of, or unauthorized access to 100,000 or more individuals’ PII. (Reference (f))
Control	Authority for NGA to maintain information and to regulate access to the information. Having control is a condition or state and not an event. Loss of control is also a condition or state that may or may not lead to an event (e.g., breach incident). (Definition created by NGA for NGA purposes only.)
Corrective Action	Any action necessary to remedy a past violation or prevent a continuing violation, including but not limited to restitution, change of assignment, disqualification, termination of an activity, waiver, or counseling. (Definition created by NGA for NGA purposes only.)
Harm	Damage, including fiscal damage, or loss or misuse of information that adversely affects one or more individuals or undermines the integrity of a system or program. Harms include anticipated threats or hazards to the security or integrity of records that could result in substantial harm, embarrassment, inconvenience, or unfairness to any individual whose information is maintained. The range also includes harm to reputation and the potential for harassment or prejudice, particularly when health or financial benefits information is involved. (Definition created by NGA for NGA purposes only.)
Individual	A citizen of the United States or an alien lawfully admitted for permanent residence. (Reference (a))
Information Technology (IT)	Any equipment or interconnected system of equipment that is used in the automatic acquisition, storage, manipulation,

UNCLASSIFIED

management, movement, control, display, switching, interchange, transmission, or reception of data or information by an executive agency. Equipment refers to that used by all NGA personnel, if the contractor requires the use of such equipment in the performance of a service or the furnishing of a product in support of NGA. The term “information technology” includes computers, ancillary equipment, software, firmware and similar procedures, services (including support services), and related resources (40 U.S.C. § 11101). The term “information system” used in this document is equivalent to “IT system.” (Definition created by NGA for NGA purposes only.)

Personally Identifiable
Information (PII)

Information that can be used to distinguish or trace an individual’s identity, either alone or when combined with other information that is linked or linkable to a specific person. (Reference (m))

Privacy Impact
Assessment (PIA)

A process required under Section 208 of the E-Government Act of 2002 by which NGA mitigates the privacy risks associated with the development or procurement of any new information technology system that contains PII, the alteration of any such existing system, or any new electronic collection of PII from 10 or more members of the public. (Definition created by NGA for NGA purposes only.)

Record

Any item, collection, or grouping of information about an individual that is maintained in an agency system of records, which includes, but is not limited to, the individual’s education, financial transactions, medical history, and criminal or employment history, and that contains an individual’s name; a unique identifying number, such as a Social Security, passport, or driver’s license number; or other identifying particular assigned to the individual, such as finger or voice print or a photograph. (Reference (k))

Risk

A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of: (i) the adverse impacts that would arise if the circumstance or event occurs; and (ii) the likelihood of occurrence. Information system–related security risks are those risks that arise from the loss of confidentiality, integrity, or availability of information or information systems and reflect the potential adverse impacts to organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, and the Nation. (Reference (h))

Senior Agency Official for
Privacy (SAOP)

Designated by the DoD Chief Management Officer, the SAOP is also known as the Director, Directorate for Oversight and Compliance (DO&C), and has DoD-wide responsibility and accountability for developing, implementing, and maintaining a

UNCLASSIFIED

DoD-wide privacy program. (Definition created by NGA for NGA purposes only.)

Senior Component Official
for Privacy (SCOP)

A member of the Senior Executive Service, a Senior level employee, or general officer or flag officer responsible for the overall implementation of the privacy and civil liberties programs in his or her DoD Component. (Reference (m))

System of Records

A group of any records under agency control about an individual from which personal information can be retrieved by the name of the individual, or by some other identifying number, symbol, or other identifying particular assigned, that is unique to the individual. (References (a) and (k))